

Part 2 (For Grades D to A)
DD2395 Computer Security
Exam 2021-10-22
14.00 – 17.00 regular time
(14.00 – 18.30 for funka code R1)

The only resources allowed are the course materials (including the course canvas, course books, and own notes). This part is only graded if Part 1 resulted in an E. Bonus points that have not been used up in Part 1 of the exam (multiple choice, to get grade E) can be used as points here. The preliminary grading is as follows:

- E: 0-9 points
- D: 10-13 points
- C: 14-17 points
- B: 18-21 points
- A: 22 or more points.

includes solutions.

1 Social engineering. [5 points]

Consider this (ficticious) scenario. Knatte is a bit short on cash as the payments from his great-uncle Joakim have stopped coming in. He does a bit of research and makes a call.
Knatte: Hej, my name is Kalle Svensson, I'm calling from Skatteverket (Swedish tax authority). Am I speaking with Alexander Lukas?
Alexander: Yes, that's me.
Knatte: Good. I'll have to verify that later, but let me first tell you what I'm calling about. Our new AI system at Skatteverket has discovered that there are 12 people registered at your apartment at Persikovägen 11, LGH 1202, with only 66m2. That's suspiciously dense.
Alexander: What, no it's just me and my nephew who live here, not 12 people, there must be some mistake.
Knatte: Well, this sometimes happens when people move and don't add the letter to the street-number, or when people let others register at their home so they can pay lower taxes. We checked and the names don't match anyone in the houses with the same number, in your case the house in the courtyard (gårdshus), Persikovägen 11A, and we're now investigating fraud.
Alexander: There is no fraud, it's just me and my nephew here.
Knatte: As I said, before we investigate any further, we'll need to verify your identity, we need you to spell out the last 4 digits of your person number and the bank you use for your Bank ID[1], to confirm.

[1]Bank ID is a Swedish identity system that is provided by several commercial entities, typically banks. On a

Alexander: Wait, how do I know you're even from Skatteverket, the phone says No Caller ID.
Knatte: Good that you point that out, you shouldn't just trust any random person calling you. Same as for other entities with potentially sensitive data, like your health-care provider, we suppress the Caller ID for mutual confidentiality. But you'll be able to check once we've verified your identity and I'll send you a confirmation. The last 4 digits? And standard Nordea?
Alexander: 7890, no, not Nordea, Handelsbanken.
Knatte: Alright, I'll send you a confirmation right away. Here we go, you should have received the Bank ID message now. Please login with your Bank ID and confirm. I see you've done that, now I'll send you the link to check the information we have about you.
Alexander: Ok. Wait, It says sknatteverket.se.
Knatte: Yes, good observation. That's the fraud branch and you need permission to access, we have to be very careful about security these days, therefore you now get another Bank ID message. Click sign and then we can see if we can clear this up or need to escalate the investigation. I'm sorry about the many steps of the process, but we take this very seriously. I'll give you a few minutes to check the data and then I'll call you back, so you'll best do that now.

1a List four of the techniques the social engineer employs and for each briefly the evidence in the scenario.

Solution: 2 out of: pretext (role of Skatteverket agent, fraud story), research (know the address and name), bolster credibility (praise critical thinking, give reasons), use threats (escalate investigation). Others may be possible.
Scoring: 2points (A) for 4 correct techniques with correct evidence, 0.5 points each, no added incorrect information. 1 point (E) for at least 2 reasons with correct evidence, some additional mistakes allowed.

1b List two of the human traits these techniques exploit and for each briefly the evidence in the scenario.

Solution: 2 out of: attribution (if serious and giving security warnings then trustworthy), fear/respect of authority (skatteverket, fraud division), reactance (threat of fraud accusation), less critical thinking under time pressure (in a few minutes). Others may be possible.
Scoring: 2 points (A) for two correct traits with correct reasoning (doesn't have to be as verbose as the sample solution), no added incorrect information. 1 point (E) for at least 2 reasons with correct evidence, some additional mistakes allowed.

1c What is the effect of the social engineering attack, i.e., what can the attacker do now that they couldn't do before?

Solution: Get the victim to sign any transaction the attacker prepared on the banking website, malware installation or web attacks by the victim clicking on sknatteverket.se, victim prepared for repeated contact.
Scoring: 1 point (E) for getting this mostly right.

2 Memory safety. [3 points] The following program inputs a string and copies it into the variable `buffer`

phone, you can have Mobile Bank ID in an app that asks you to login or sign when prompted by the web service you're using. Typically, you get the Mobile Bank ID from your bank, you use your person number to start logging in to the web service, who tells the bank which in turn makes sure the requests are sent to your phone. There you authenticate (login) and authorize (sign) with a PIN code.

```
function void do_damage() {
  ...
}

void do_something(char * input) {
     int chars = 0;
     buffer[1024];
     while (*input != NULL) {
           buffer[chars] = *input;
           chars += 1;
           input ++;
     }
     return;
}
```

The program has a bug that can cause the execution of `do_damage`.

2a Explain the bug and provide an input that causes the execution of `do_damage`. You can make assumptions about the memory layout to come up with an input that executes `do_damage`.

Solution: [If the?] There `input` has more than 1024 characters the program causes overflow of `buffer`. Assuming that `buffer` is allocated on the stack below `chars`, and that the integer consists of 4 bytes, a string consisting of $1024 + 4 + 4$ 1-s followed by the asci encoding of the address of `do_damage` will override the frame pointer with the encoding of 1s and the return pointer with the address of `do_damage`. When the main function will return, it will pop the modified value for the return pointer, jumping to the malicious function.

2b Propose a solution to fix the procedure.

Solution: Loop should break after 1023 iterations and null-terminate `buffer`.

3 Side channels. [3 points] Imagine that you have a computer architecture that has no native multiplier and you implement multiplication of a and b as follows:

```
1: r = 0
2: if b == 0 GOTO end
3: r = r + a
4: b = b - 1
5: GOTO 2
```

assume that a and b are 4 bit unsigned integers (i.e. $a < 16$ and $b < 16$) and that r is a 8 bit integer.

3a Describe the information that can be leaked via a time channel.

Solution: The number of iterations of the loop depends on b. Assuming that all instructions are executed in constant time t, the execution time will be $(2 + 4 * b) * t$, hence it is directly proportional to b.

3b Propose a countermeasure to avoid this channel.

Solution: There are several option.

- evaluate worst case execution time of the system and wait at the end of the function (i.e. (2+4*15)*b)
- guarantee that the loop is always executed 15 times, but the body adds 0 when b becomes 0

4 Hash functions. [5 points] Let H be a hash function that is **not** one-way. Can H be collision resistant? Motivate, as formally as you can, your answer: e.g. show a hash function that is not one-way and is collision resistant; or show that if function is not one-way then it is not collision resistant.

Solution: In general no. If a function H it not one way than given y it is easy to find a x such that $H(y) = x$. We use $g(y)$ as the easy function that finds such x. Notice that the domain of g is the image of H (i.e. 256 bits for SHA). Now, if we have an arbitrary input x_1, we can easily compute $g(H(x_1)) = x_2$. If $x_2 \neq x_1$ we have easily found a collision (which invalidates weak collision resistance). There could be some x_1 such that $g(H(x_1)) = x_1$. However, since g is a function, its image is smaller or equal to its domain (i.e. the image of H), therefore we can conclude that weak collision resistance can only hold for a small part of the inputs of H, which is bounded by the side of the image of H.

5 Authentication and access control [5 points]
The Electronic Certification Company (ECC) specializes on electronic certification of all kinds of things. The ECC develops custom solutions for its customers.
One of their customers is the Packet Peddling Postal Company (P3C, pronounced pec). You are the lead developer/designer/architect for the P3C project. They summarized their use case as follows:

> We want to deliver packages to special postboxes located in shops, we call them P3C boxes. The store can't access them, it's our boxes; we just rent the space in popular shops where recipients likely pass often. The recipient comes and unlocks the box to fetch the package whenever they like, no staff involved.
>
> We also do home delivery, it's the pricey premium option. Then we bring the package to the recipient's door. The recipient can choose what will happen if the recipient is not at home: we can leave the package outside the door (or in the mailbox if it fits), or drop it in the nearest P3C box facility.

As the lead on the project, you should design a proper solution. (Read through all subproblems before you start, they are related.)

5a Identify a threat related to authentication and access control[2]. Answer what is the threat and why, as well as who the adversary is?

This part allows the students to "analyze system descriptions in terms of their security to identify vulnerabilities and predict their corresponding threats". They can do this at different levels, from the grading criteria:

E finding obvious problems with few mistakes,

[2]Remember the grading criteria: [E] finding obvious problems with few mistakes, [C] finding obvious problems correctly, [A] finding subtle problems correctly. You may list several in case you're unsure whether one is obvious or subtle.

C finding obvious problems correctly,

A finding subtle problems correctly.

B and D are for in-between cases.

Solution: An obvious problem is that we must lock the boxes and that only the recipient should be able to access a box until they have fetched their package.
A subtle problem is that the recipient fetches the package, but try to claim that someone else did — *i.e.*, that the package was stolen.
Another subtle problem is related to home delivery, is that the recipient might claim that P3C never delivered the package.
Yet another one is that the P3C delivery person might check that no one is home, then steal the package.
Anything related to privacy is subtle, *e.g.*, data might leak to different parties.
But there can be other problems too that the students identify.

5b Suggest a counter measure for the threat you described. Why does it solve the problem?[3]

This part allows students to "select counter-measures to identified threats and argue their effectiveness". They can do this at different levels:

E with some appropriate counter-measures and basic argumentation, with few mistakes;

C with some appropriate counter-measures and basic argumentation, correctly;

A with arguably most appropriate counter-measures and nuanced argumentation.

B and D are for in-between cases.

Solution: Suggestions for two cases from above:
How to lock the boxes: P3C generates a public–private key pair. The public key is uploaded to the P3C box and the other is sent to the recipient's app. When the recipient wants to fetch the package it lets the P3C app prove knowledge of the corresponding private key.
We could do the same with a four-digit code, just then the user enters it. But that would yield only a C. Unless there is some way of preventing guessing attacks also suggested.
Someone else fetched the package: This might be the case with a four-digit code (only 10 000 different codes after all). This is not as likely with the cryptographic approach suggested above. However, P3C want non-repudiable proof of who fetched the package. We can complement the cryptographic scheme with a proof of identity using an electronic ID. To reduce any claims of relay attacks, we also want this to be distance bounded.

5c Analyze your solution and evaluate any side-effects. Why is your suggested counter measure better or worse than any other counter measure?[4] (You probably considered several for the previous question anyway.)

[3] Remember the grading criteria: [E] with some appropriate counter-measures and basic argumentation, with few mistakes; [C] with some appropriate counter-measures and basic argumentation, correctly; [A] with arguably most appropriate counter-measures and nuanced argumentation.

[4] Remember the grading criteria: [E] from list with given effects, with few mistakes, [C] with basic argumentation and list of side effects, [A] setting up own criteria, nuanced argumentation, comprehensive list of side effects.

This allows the students to "compare counter-measures and evaluate their side-effects". This can be done at different levels:

E from list with given effects, with few mistakes,

C with basic argumentation and list of side effects,

A setting up own criteria, nuanced argumentation, comprehensive list of side effects.

B and D are for in-between cases.

Solution: The students should analyze their own solution and the side-effects they imply. Furthermore, they can set up own criteria, such as complexity or privacy. How does it work with recovery? Do those involved reveal the least possible data?
The solution with the four digit code is easy to implement, it has the advantage of people having used similar constructions before. The recipient also doesn't need any device to fetch the package. The downside is that it is easy to guess.
The cryptographic key requires that the recipient has a smartphone. But this is probably fine, the recipient needed some device to receive the code on anyway, so s/he might just as well receive a cryptographic key in an app. The advantage of this one is that it's more secure. The downside is that if the phone dies there is no recovery, whereas the code could've been memorized.
Both are privacy preserving, no identity is needed for either.
The accountability in the someone-else-fetched scenario is privacy invasive. P3C doesn't need to learn the identity. The P3C box can take a picture of the person who fetches the package, but then it's the problem of detecting masks.
Scoring: A gives 5 points, B gives 4 points, ..., E gives 1 point. The final score of this question is the average score of the subproblems above (5a, 5b, 5c).

6 Intrusion detection and prevention [5 points] Now, we must also consider the infrastructure that P3C needs for running the service. More of P3C's requirements:

> We want to keep track of our infrastructure. We need to know how many P3C boxes are available at a given location at any given time; so the P3C boxes must be online, so that we know when a box is emptied so that we can use it for another package. This is to optimize our logistics.

(Read through all subproblems before you start, they are related.)

6a Identify a threat to P3C's infrastructure (servers or P3C boxes) related to intrusion detection and prevention[5]. Answer what is the threat and why, as well as who the adversary is?

This part allows the students to "analyze system descriptions in terms of their security to identify vulnerabilities and predict their corresponding threats". They can do this at different levels, from the grading criteria:

E finding obvious problems with few mistakes,

C finding obvious problems correctly,

A finding subtle problems correctly.

B and D are for in-between cases.

[5]Remember the grading criteria: [E] finding obvious problems with few mistakes, [C] finding obvious problems correctly, [A] finding subtle problems correctly. You may list several in case you're unsure whether one is obvious or subtle.

Solution: An obvious problem is that someone might try to communicate with the P3C boxes or servers to unlock a box to steal a package.
A more subtle ...
But there can be other problems too that the students identify.

6b Suggest a counter measure for the threat you just described (intrusion detection and prevention). Why does it solve the problem?[6]

This part allows students to "select counter-measures to identified threats and argue their effectiveness". They can do this at different levels:

E with some appropriate counter-measures and basic argumentation, with few mistakes;

C with some appropriate counter-measures and basic argumentation, correctly;

A with arguably most appropriate counter-measures and nuanced argumentation.

B and D are for in-between cases.

Solution: An appropriate counter-measure is to establish a whitelist for access to the database using a firewall. (This way only the server is able to connect.)
One possibly most appropriate counter-measure is to have an intrusion detection system monitor the web and database servers. This way we might be able to detect data exfiltration, such as extracting the entire database of bids.

6c Analyze your solution and evaluate any side-effects. Why is your suggested counter measure better or worse than any other counter measure?[7] (You probably considered several for the previous question anyway.)

This allows the students to "compare counter-measures and evaluate their side-effects". This can be done at different levels:

E from list with given effects, with few mistakes,

C with basic argumentation and list of side effects,

A setting up own criteria, nuanced argumentation, comprehensive list of side effects.

B and D are for in-between cases.

Solution: *E.g.*, the intrusion detection system requires more resources than the firewall solution.
Scoring: A gives 5 points, B gives 4 points, ..., E gives 1 point. The final score of this question is the average score of the subproblems above (6a, 6b, 6c).

[6] Remember the grading criteria: [E] with some appropriate counter-measures and basic argumentation, with few mistakes; [C] with some appropriate counter-measures and basic argumentation, correctly; [A] with arguably most appropriate counter-measures and nuanced argumentation.

[7] Remember the grading criteria: [E] from list with given effects, with few mistakes, [C] with basic argumentation and list of side effects, [A] setting up own criteria, nuanced argumentation, comprehensive list of side effects.